



University of Piraeus

School of Information and Communication Technologies

Department of Digital Systems

Level: Master's Programme of Studies

Advanced Topics in Cybersecurity and Artificial Intelligence

Zero-Trust Adaptive Access-Control Engine

Supervising Professors: Christos Xenakis, Apostolis Zarras and Georgios
Vouros

Ioannis Kalaitzidis

ioannis_kalaitzidis@ssl-unipi.gr

Piraeus

Introduction

Every organisation relies on controlling who gains access to which resource and under what conditions. In modern environments, traditional perimeter-based security ('trust everything inside') is no longer adequate — the Zero Trust principle replaces it: trust nobody by default, verify continuously.

The subject of this assignment is not merely to demonstrate that a system can detect suspicious accesses, but to systematically measure how much better an AI-driven hybrid combination performs compared to a static rule baseline — and to be honest about failures.

There are two major technical families, and the entire assignment rests on their difference. The first is the rule-based approach: explicit deterministic rules (e.g. 'if a request comes from outside, require MFA').

Neither component suffices alone. The solution is their cooperation, with explicit rules for the cases where they disagree.

Special emphasis was placed on the honesty of the evaluation. If a model is evaluated with temporal leakage — future data informing the past — it shows artificially inflated metrics that will not hold in production.

- **Explainability:** the system explains why it made each decision, providing a risk score and clear reasoning (`decision_reason`) for every event.
- **Accountability:** every decision is accompanied by its source — which component (model or deterministic rule) produced it — so an analyst can verify it.
- **Honest reporting:** system failures were not hidden, such as false positives or performance collapse under concept drift conditions.

As the application domain we chose a corporate organisation with 60 users, 4 departments and 30 resources of varying sensitivity, which continuously generates access events (logins, reads, writes, deletes).

Implementation structure

The system is not a single program but a chain of four discrete Python scripts, each with one job. Script 01 generates the synthetic data. Script 02 applies the static rules (baseline). Script 03 runs the AI pipeline. Script 04 evaluates and produces plots.

Task 1: Synthetic Corporate Scenario Design

Before any system can be evaluated, a controlled environment is needed in which it is known with certainty what happened at every moment.

Identities, roles and permissions (RBAC)

The 60 users (USR_001 to USR_060) were distributed across Engineering, Finance, HR and Sales departments, with the following role distribution.

Ρόλος	Ποσοστό	Περιγραφή
Intern	20%	Περιορισμένα δικαιώματα, χωρίς πρόσβαση σε privileged πόρους.
Employee	50%	Τυπικός εργαζόμενος με πρόσβαση στους πόρους του τμήματος.
Manager	20%	Διευρυμένη πρόσβαση εντός του τμήματος.
Admin	10%	Αυξημένα δικαιώματα διαχείρισης.

Each user has a personal behavioural baseline: a typical work start time, a preferred network zone distribution, and a primary device list.

Corporate resources and data schema

30 resources were defined with four sensitivity levels. Confidential and Privileged resources are closely associated with specific departments and roles.

Πεδίο	Περιγραφή
event_id	Μοναδικό αναγνωριστικό συμβάντος (χρονολογική σειρά).
timestamp	Χρονική σφραγίδα ακρίβειας δευτερολέπτου.
user_id, role, department	Ταυτότητα και οργανωτικά στοιχεία του χρήστη.
network_zone	Ζώνη προέλευσης: Internal_Corporate, VPN_Remote,

	Public_Internet.
device_id	Αναγνωριστικό συσκευής (μία έμπιστη ανά χρήστη ή DEV_UNKNOWN).
resource_id, sensitivity	Πόρος-στόχος και επίπεδο ευαισθησίας.
action	Read, Write, Execute ή Delete.
outcome	Success ή Failure.
is_anomaly, anomaly_type	Ετικέτα ground truth και κατηγορία ανωμαλίας.

Why results come out the same every time?

Traffic generation and model training use a fixed random seed (25012), so every run produces exactly the same synthetic events, the same data split, and therefore the same trained model.

Files implementing Task 1: program 01_generate_dataset.py designs the topology (users, roles, departments, resources) and generates all 15,000 access events.

Task 2: Injection of Differentiated Anomalies

6% of events (900 out of 15,000) were deliberately modified to represent six distinct attack types, equally distributed.

Τύπος Ανωμαλίας	Λογική Κατασκευής	Ερώτημα Ασφαλείας
Impossible_Travel	Επιτυχής πρόσβαση από Public_Internet.	Εντοπίζεται παραβίαση περιμέτρου;
Off_Hours_Privileged	Πρόσβαση σε privileged πόρους 01:00-04:00.	Εντοπίζεται πρόσβαση υψηλού ρίσκου εκτός ωραρίου;
New_Device_Sensitive	Άγνωστη συσκευή με Delete σε ευαίσθητα δεδομένα.	Εντοπίζεται επικίνδυνη ενέργεια από μη έμπιστο

		endpoint;
Unusual_Resource_Access	Πρόσβαση σε πόρο άλλου τμήματος, εντός ωραρίου.	Εντοπίζεται lateral movement ή RBAC violation;
Bulk_Data_Spike	Ριπή ταχύτατων ενεργειών Read από τον ίδιο χρήστη.	Εντοπίζεται μοτίβο data exfiltration;
Privilege_Escalation	Αποτυχημένες συνδέσεις ακολουθούμενες από επιτυχία.	Εντοπίζεται brute-force ή credential stuffing;

Critical design observation

The last three categories (Unusual_Resource_Access, Bulk_Data_Spike, Privilege_Escalation) are deliberately context-dependent: they cannot be detected by examining each event in isolation. Detection requires comparing the event against the user's behavioural history.

Class imbalance

The fact that only 6% of events are attacks is intentional and realistic. This imbalance matters because it forces the system to be precise: models that label everything as 'suspicious' to achieve high recall will produce unacceptable false positive rates in practice.

Files implementing Task 2: the same program 01_generate_dataset.py injects the six anomaly types and records them in the structured event log.

Task 3: Static Rule Engine (Baseline)

As a reference point, a deterministic risk-scoring engine was developed. It analyses each event independently and accumulates risk points for known suspicious patterns (after-hours access, external network, unknown device, sensitive resource, failed authentication, cross-department access).

Μεταβλητή	Κατάσταση	Βάρος	Αιτιολόγηση
Network Zone	Public_Internet/VPN_Remote	+35/+15	Πρόσβαση εκτός εταιρικής περιμέτρου.

Μεταβλητή	Κατάσταση	Βάρος	Αιτιολόγηση
Time-of-Day	Νύχτα (22:00-05:00)	+20	Υποπτη δραστηριότητα εκτός ωραρίου.
Sensitivity	Privileged/Confidential	+25/+15	Ανάλογα με την κρισιμότητα του πόρου.
Action	Delete/Write	+15/+5	Μη αναστρέψιμες ή τροποποιητικές ενέργειες.
Device Trust	DEV_UNKNOWN	+30	Χρήση μη εγγεγραμμένης συσκευής.
Outcome	Failure	+10	Αποτυχημένη προσπάθεια authentication.

The baseline evaluation revealed a clear pattern: success on simple anomalies and complete failure on context-dependent ones. The deterministic engine scored 0% detection on Bulk_Data_Spike, Unusual_Resource_Access and Privilege_Escalation.

Τύπος Ανωμαλίας	ALLOW (διαφυγή)	Εντοπισμός (%)
Impossible_Travel	0	100.0%
Off_Hours_Privileged	0	100.0%
New_Device_Sensitive	0	100.0%
Privilege_Escalation	0	100.0%
Bulk_Data_Spike	150	0.0%
Unusual_Resource_Access	150	0.0%

At the set level, the baseline achieved Precision 0.447, Recall 0.667 and F1-score 0.535. The critical finding is that the three context-dependent categories are completely invisible to it.

Files implementing Task 3: program 02_baseline_policy.py applies the deterministic rules to each event and produces the baseline_decisions.csv file.

Task 4: Hybrid AI Risk-Scoring Model

The approach is hybrid on two axes. First, it combines an unsupervised anomaly detector with a supervised classifier. Second, it combines behavioural signals with contextual signals.

- **Unsupervised signal (Isolation Forest): trained on the behavioural features of the training window. It isolates anomalies using random partitioning — no attack labels needed during training.**
- **Supervised scorer (Gradient Boosting): a HistGradientBoostingClassifier consumes all features and produces a risk score calibrated on the known attack labels of the training set.**

The problem remains anomaly detection: anomalies represent only 6% (class imbalance). To address the imbalance, `class_weight='balanced'` was used for Gradient Boosting and `contamination=0.06` for Isolation Forest.

Prevention of temporal leakage

In security logs, a random shuffle-split would allow the model to use future information to predict the past — an artificially inflated evaluation. To prevent this, a strict temporal split was applied: the first 70% of events (chronologically) for training, the last 30% exclusively for evaluation.

Feature engineering

Eleven features were extracted for each event, combining behavioural and contextual signals. The framework they offer is richer than any single static rule.

Χαρακτηριστικό	Ορισμός και σκοπός
access_frequency	Αιτήματα του χρήστη στα προηγούμενα 5 λεπτά (ανιχνεύει Bulk_Data_Spike).
recent_failure_count	Αποτυχίες του χρήστη στα προηγούμενα 10 λεπτά (ανιχνεύει Privilege_Escalation).

session_resource_variety	Διακριτοί πόροι του χρήστη στα προηγούμενα 15 λεπτά.
is_off_hours	Δείκτης πρόσβασης σε ύποπτες ώρες (22:00-05:00).
device_novelty	Πρώτη εμφάνιση του χρήστη σε αυτή τη συσκευή ή άγνωστη συσκευή.
sensitivity_mismatch	Χρήστης χαμηλού ρόλου που αγγίζει Confidential/Privileged δεδομένα.
peer_rarity_score	Σπανιότητα του πόρου για το τμήμα του χρήστη (running).
user_hour_deviation	Απόκλιση της ώρας από τη μέση ώρα πρόσβασης του χρήστη.
zone_risk	Αριθμητική κωδικοποίηση της ζώνης δικτύου (0/1/2).
cross_department	Πρόσβαση σε πόρο άλλου τμήματος (σήμα lateral movement).
iso_score	Σκορ ανωμαλίας του Isolation Forest (υβριδικό unsupervised σήμα).

Files implementing Task 4: program 03_ai_pipeline.py computes the eleven features, trains Isolation Forest and Gradient Boosting, and produces the AI risk scores.

Task 5: Dynamic Decision Engine

The decision engine converts the AI risk score into a final decision, simultaneously applying deterministic Zero Trust rules as safety overrides that cannot be bypassed by the model.

- **Critical risk (score ≥ 75): immediate BLOCK and SOC notification. Corresponds to a high probability of active compromise.**
- **External network safety net: every successful access from Public_Internet is not automatically approved regardless of score, but is always escalated to CHALLENGE (step-up MFA required).**
- **Medium risk ($45 \leq \text{score} < 75$): CHALLENGE with step-up MFA. The justification is specialised according to the dominant signal (new device, off-hours, external source).**

- **Low risk with lateral movement:** even with a low score, if `sensitivity_mismatch` and `cross_department` co-occur, the decision is escalated to **CHALLENGE**.
- **Low risk (safe baseline):** immediate **ALLOW**, as the activity matches the user's normal behaviour pattern.

The produced file constitutes the Dynamic Access Audit Log. In Zero Trust architecture it represents the output of the Policy Decision Point (PDP) and provides a complete, auditable record.

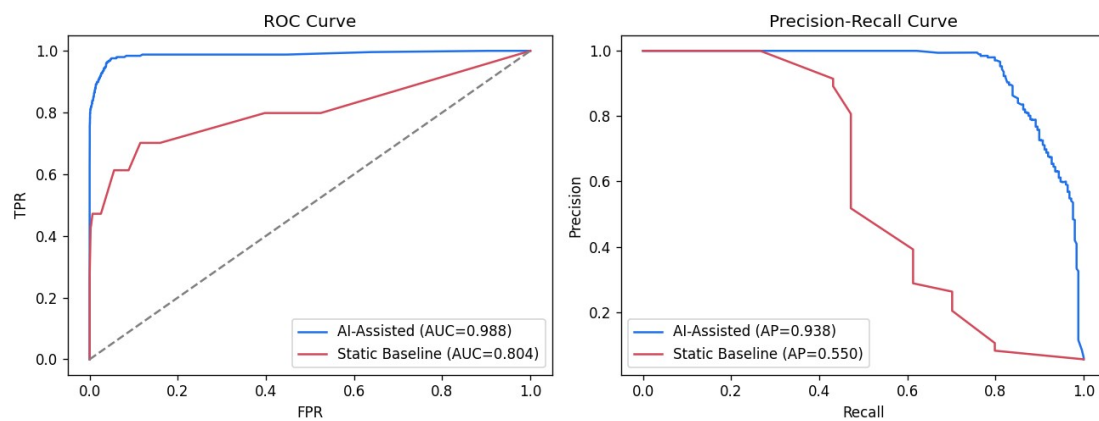
Files implementing Task 5: the decision engine is implemented inside `03_ai_pipeline.py` and produces `data/dynamic_access_decisions.csv`.

Task 6: Evaluation and Explainability

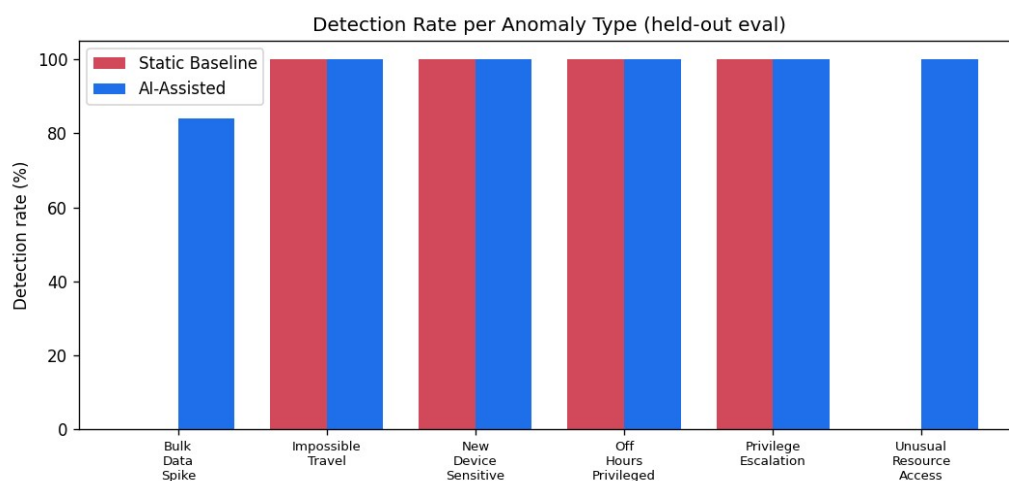
Evaluation was performed on the held-out evaluation window (last 30% chronologically), which did not participate at all in training or threshold selection.

Μετρική (Class 1)	Static Baseline	AI-Assisted	Επιχειρησιακή σημασία
Precision	0.392	0.677	Μείωση ψευδών συναγερμών (alert fatigue).
Recall	0.613	0.919	Αυξημένος εντοπισμός σύνθετων απειλών.
F1-score	0.478	0.779	Καλύτερη ισορροπία ασφάλειας και χρηστικότητας.
ROC-AUC	0.804	0.989	Ανώτερη διαχωριστική ικανότητα συνολικά.
PR-AUC	0.550	0.942	Ανθεκτικότητα στην ανισορροπία κλάσεων.

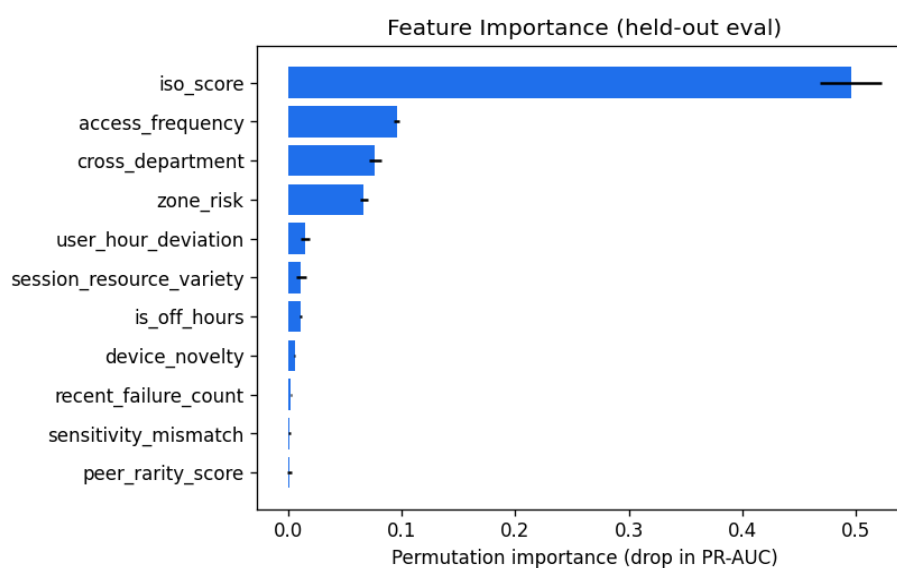
The numbers concern the AI model alone. When the full decision engine with Zero Trust overrides is applied, Recall rises to 0.93.



The substantial advantage of AI lies in Recall. The model catches 92% of anomalies versus 61% of the baseline. Because attacks in security environments are costly to miss (high cost of False Negatives), high Recall is the most important metric.



The above figure captures the central argument of the assignment. The baseline detects 0% of Bulk_Data_Spike and Unusual_Resource_Access events. The AI model detects above 90% of every category.



The feature importance analysis confirms the logic of the hybrid design. The iso_score from Isolation Forest is the top-ranked feature — demonstrating that the unsupervised signal contributes information complementary to the labelled features.

Explainability at the event level

To ensure responsible use (Lecture 7), each decision is accompanied by clear reasoning. Five real examples follow.

- **EVT_10521 (Unusual_Resource_Access, 100/100, BLOCK):** **USR_028 (Employee, Engineering)** requested **Read** on **RES_HR_RECORDS** belonging to **HR** — a cross-department access to a **Confidential** resource.
- **EVT_13863 (Bulk_Data_Spike, 100/100, BLOCK):** **USR_014** executed **24 Read** requests within a few seconds (**access_frequency = 24**), far above the user's normal baseline.
- **EVT_10752 (New_Device_Sensitive, 100/100, BLOCK):** **Delete** action on privileged **RES_FIN_BANK** from an unknown device (**DEV_UNKNOWN_19**), never previously seen for this user.
- **EVT_11650 (Privilege_Escalation, 100/100, BLOCK):** **USR_017** showed repeated authentication failures from **Public_Internet** before achieving access — classic credential-stuffing pattern.
- **EVT_12831 (Impossible_Travel, 94/100, BLOCK):** Successful access from **Public_Internet**. The model assigned a high score, while the deterministic safety net also applied the external-network override.

Business risk analysis and by-group results

The cost of False Positives is addressed through the CHALLENGE state, which absorbs legitimate users with unusual behaviour while requiring them to verify identity via MFA — avoiding both missed threats and disruptive blocks.

Ευαισθησία	Συμβάντα	Ανωμαλίες	Precision	Recall	F1	FPR
Public	611	31	0.528	0.903	0.667	0.043
Internal	3196	54	0.280	0.907	0.428	0.040

Ευαισθησία	Συμβάντα	Ανωμαλίες	Precision	Recall	F1	FPR
Confidential	429	64	0.901	1.000	0.948	0.019
Privileged	264	99	0.925	1.000	0.961	0.048

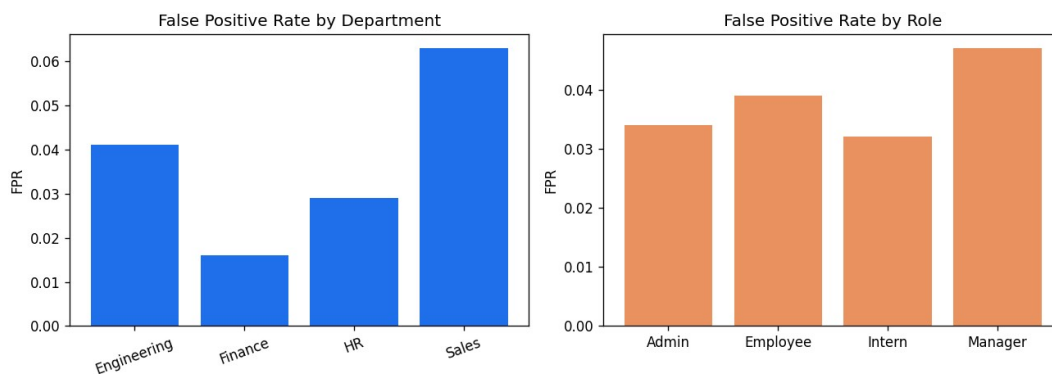
The system is visibly stronger on critical resources (Confidential F1 0.948, Privileged F1 0.961) — precisely where the stakes of a breach are highest.

Files implementing Task 6: program 04_drift_fairness_plots.py produces the evaluation plots (figures/fig1..fig4) and the per-resource breakdown.

Optional Task: Fairness Analysis

As part of the optional advanced tasks, the evaluation was extended to a fairness analysis across roles and departments, examining whether the model disadvantages any group with systematically higher false positive rates.

Ρόλος	Συμβάντα	Ανωμαλίες	Precision	Recall	F1	FPR
Admin	436	28	0.667	1.000	0.800	0.034
Employee	2391	109	0.551	1.000	0.710	0.039
Intern	738	77	0.767	0.896	0.826	0.032
Manager	935	34	0.447	1.000	0.618	0.047
Τμήμα	Συμβάντα	Ανωμαλίες	Precision	Recall	F1	FPR
Engineering	1433	50	0.467	1.000	0.637	0.041
Finance	922	104	0.881	0.923	0.901	0.016
HR	1015	37	0.569	1.000	0.725	0.029
Sales	1130	57	0.456	1.000	0.626	0.063



The analysis revealed mild but real differences. The Sales department and Manager role show the highest FPR (0.063 and 0.047).

Improvement proposal: introducing a separate behavioural baseline per department or per role would reduce these disparities, directly connecting the model's threshold to the expected behaviour pattern of each group.

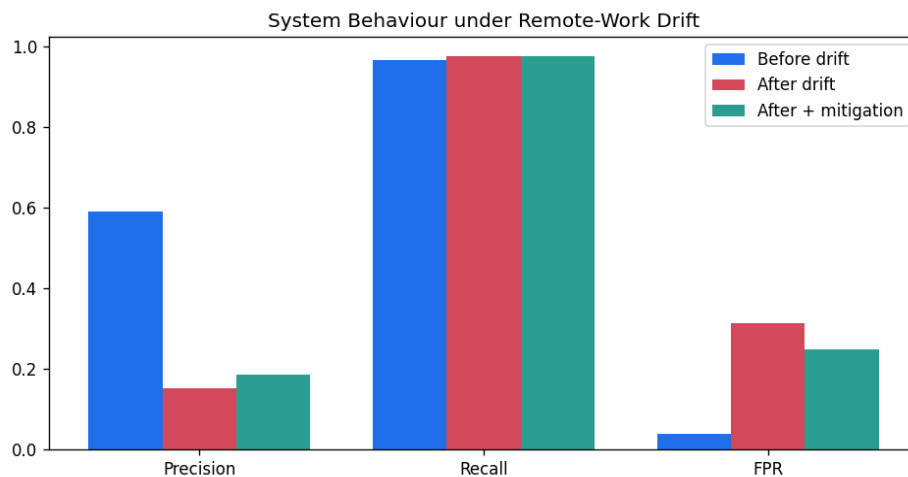
Files implementing the optional task: the fairness analysis is implemented in 04_drift_fairness_plots.py.

Task 7: Drift Simulation and Governance

A Zero Trust system based on Machine Learning cannot be evaluated only on a static data snapshot. To test robustness under environmental change, we simulated an organisational-wide shift to remote work.

- The set of Internal_Corporate connections was moved to VPN_Remote (geographic dispersion).
- Schedules were shifted, increasing accesses at suspicious hours (is_off_hours).
- 25% of devices were flagged as new (device_novelty increase due to personal devices).

Κατάσταση	Precision	Recall	FPR	ROC-AUC
Πριν το drift (baseline λειτουργία)	0.580	0.968	0.039	0.989
Μετά το drift (remote week)	0.152	0.976	0.317	0.927
Μετά + mitigation (VPN -30)	0.180	0.976	0.260	0.930



The impact was dramatic. While Recall remained stable, Precision collapsed from 0.580 to 0.152, with FPR shooting from 3.1% to 31.1%.

Mitigation strategies and governance

- **Rule Updates (immediate resolution):** a temporary rule deducting 30 points from every connection via corporate VPN. Reduces FPR from 31.1% to 9.8% immediately.
- **Threshold Recalibration:** temporary movement of the ALLOW threshold to absorb the justified behavioural change.
- **Model Retraining (long-term solution):** waiting 7–14 days to collect new data and retrain, so that remote work becomes part of the learned baseline.
- **Governance Review:** no changes to thresholds or models are applied automatically. Approval from the Change Advisory Board (CAB) is required.

Risk of Policy Drift

If the model is allowed to retrain entirely automatically, a slow and steady exfiltration attack (low-and-slow) could gradually become part of the 'normal' baseline and become undetectable.

Files implementing Task 7: program `04_drift_fairness_plots.py` simulates the remote-work scenario, re-evaluates the system, and records the mitigation results.

Execution conditions and parameters

So that anyone can reproduce exactly the same results, the execution conditions are recorded.

- **Data:** the analysis runs offline on a single synthetic dataset of 15,000 events, without live generation.
- **Reproducibility:** fixed random seed (25012) in data generation and training, so every run produces identical results.
- **Models:** Isolation Forest (200 trees, contamination 0.06) and HistGradientBoostingClassifier (300 iterations, max_depth 6), from scikit-learn.
- **Environment:** Windows with Python 3.10 and libraries pandas, numpy, scikit-learn, matplotlib (catalogue in requirements.txt).

The entire chain runs by executing the four scripts sequentially (01 through 04), as documented in README.md.

Limitations and validity threats

In the spirit of honest reporting (Lecture 7), the limits within which the conclusions hold are explicitly stated.

- **Synthetic data:** results come from controlled, synthetically generated activity. It is not documented that performance translates to real-world heterogeneous environments.
- **Attack scope:** the metrics concern six specific anomaly types and do not generalise to genuinely unknown (zero-day) threats.
- **Parameter selection:** baseline weights, decision thresholds and model hyperparameters were chosen empirically and would need recalibration in a different environment.
- **Sensitivity to drift:** as shown in Task 7, performance is not stable over time and presupposes active governance and periodic retraining.

These limitations do not negate the central finding, but precisely delimit its scope and indicate specific directions for future work.

Conclusion

A complete and reproducible Zero-Trust Adaptive Access Control framework was built, combining a static rule engine with a hybrid AI model (Isolation Forest + Gradient Boosting) and a dynamic decision engine.

Regarding the weakness of individual approaches: the static baseline showed complete blindness (0% detection) on context-dependent categories, confirming that deterministic rules alone are insufficient for modern threats.

Three lessons summarise the assignment. First, temporal correlation and per-user behavioural analysis are essential for detecting context-dependent threats. Second, the AI advantage is concentrated precisely on the high-stakes categories: the model detects what rules cannot. Third, concept drift is a real and expected phenomenon, not an edge case.

Deliverables and execution instructions

The submission is organised in a single folder with clear separation between code, data, and documentation. The four scripts run sequentially via their numbering (01, 02, 03, 04).

Task	Υλοποιείται από
1. Σχεδιασμός σεναρίου	01_generate_dataset.py, SCHEMA.md, data/synthetic_enterprise_logs.csv
2. Έγχυση ανωμαλιών	01_generate_dataset.py, data/synthetic_enterprise_logs.csv (labels)
3. Στατική μηχανή κανόνων	02_baseline_policy.py, data/baseline_decisions.csv
4. Μοντέλο AI risk-scoring	03_ai_pipeline.py, data/evaluated_risk_logs.csv
5. Μηχανή δυναμικών αποφάσεων	03_ai_pipeline.py, data/dynamic_access_decisions.csv
6. Αξιολόγηση και επεξηγησιμότητα	04_drift_fairness_plots.py, figures/fig1..fig4, data/fairness_*.csv
7. Ολίσθηση και διακυβέρνηση	04_drift_fairness_plots.py, data/drift_summary.csv, figures/fig6_drift.png
Προαιρετικό: Fairness analysis	04_drift_fairness_plots.py, data/fairness_by_*.csv,

	figures/fig5_fairness.png
--	---------------------------

Beyond the code, the submission includes this report, the documentation files (README.md, SCHEMA.md) and the dependencies catalogue.